

Actividad 01

Análisis y Planificación del Pentest

Victoria Maria Rivas Arechiga

Hacker Women Council Ethical Hacking



1.



OBJETIVO DEL PENTEST

Define 3 objetivos concretos que tendría la evaluación de seguridad de **Aurora Market**.

Nuestro objetivo concreto es analizar la seguridad y alcances que tiene Aurora Market en su pagina web. Que tanta informacion puede llegar a obtener un hacker y hasta donde puede quedar expuesta la informacion de los usuarios, trabajadores o CEO.

En base a lo encontrado se realizara una documentacion, sobre estas vulnerabilidades y el como resolverlo.

2.



ALCANCE

Identifica claramente qué se evaluará y qué queda fuera del alcance.



SÍ SE EVALUARÁ

- Autorización sobre la aplicación web



FUERA DEL ALCANCE

- No brindan información técnica, sistemas o sobre la infraestructura
- Redes sociales de la empresa
- Equipos personales de los empleados
- Cuentas de correos
- Proveedores externos

3.



AUTORIZACIÓN Y CONDICIONES

Explica qué permisos y condiciones deben estar definidos antes de comenzar las pruebas.



PERMISOS REQUERIDOS

- Llegar a un acuerdo sobre hasta donde podemos llegar con la plataforma web, debido a que también sabemos que cuentan con diferentes tipos de usuarios, bases de datos (nombres, direcciones y productos) no sabemos que autenticación utilizan, podrían estar comprometidas, pero no contamos con acceso a ellas
- Horarios y días en los que podemos realizar nuestro pentesting.



CONDICIONES ACORDADAS

- No interrumpir el funcionamiento de la plataforma
- Afectar la información de los clientes
- Hacer una documentación sobre la evaluación que permita a Aurora Market conocer los objetivos y alcances que puede tener un atacante y como tomar medidas en ello.

4.



TIPO DE PENTEST

Determina si el escenario corresponde a un:

Black-box, Gray-box o White-box.

Investiga brevemente el concepto y justifica tu elección.

El tipo de pentest es Black-blox.

Justificación:

Elegí black-box ya que contamos solo con el acceso de su pagina web, sin acceso a infraestructura con la finalidad de ver cómo se comportaría un atacante el cual no tiene información de absolutamente usuarios o equipos de la misma empresa, conociendo las vulnerabilidades desde cero.

5.



PLANIFICACIÓN

Establece qué debería hacer el equipo antes de comenzar la parte técnica. Completa los elementos clave.



OBJETIVOS

- Verificar con Aurora Market días y horarios en los que podremos hacer nuestro pentest
- Hay que concretar que tanto alcance tendremos en para hacer la prueba en la aplicación web además de los acuerdos ante las cosas que no se les harán pentesting.
- Verificar con la empresa que tipo de ataques han tenido, en base a ello planificar como abordar las vulnerabilidades
- Documentar todas las vulnerabilidades encontradas de manera que el cliente pueda serle fácil entender y remediar.



ALCANCE

- Solo podemos utilizar la aplicación web de Aura Market



PERMISOS Y CONDICIONES

- Respetar el acuerdo de la empresa, sin vulnerar horarios de mayor movimiento, o hacer cambios en algún usuario, vulnerar los equipos personales como redes sociales de los mismos.



METODOLOGÍA A UTILIZAR

PTES + OWASP

PTES nos brindara ayuda con la estructura del pentesting

OWASP nos ayudara a documentar la forma de remediar las vulnerabilidades con ejemplos para corregirlos de manera óptima.



RECOPILACIÓN DE INFORMACIÓN PREVIA

Necesitamos documentar el alcance que tendremos en Aurora Market, para de esa manera verificar si podremos usar herramientas tipo open source que a mi parecer pueden ser le mejor recurso, debido a que es la primera vez que realizan un test de seguridad. Se utilizara reconocimiento pasivo y pasivo con OSINT: como Nmap y DNS enumeration, whatweb, y en caso de nos permitan utilizar software de paga podria ser Burp suite, para verificar el sitio web y las API, si es que el alcance que tenemos nos permite utilizarlo para ver mas a fondo que pasa dentro de la aplicacion en si.



RECURSOS NECESARIOS

Documentación desde el inicio a fin, con los horarios y permisos que tenemos, nuestra pagina web si nos pasaran alguna que sea de producción o si tienen algún ambiente de pruebas, nuestras herramientas donde podríamos utilizar las herramientas tal vez open source, por último documentar nuestras vulnerabilidades tanto para un IT como para una persona no técnica.



PROGRAMACIÓN DEL PENTEST

Se sugiere que el pentest se realice en un horario nocturno 12:00pm a 5am, ya que es un horario en el no hay tanto movimiento y no se interviene con el usuario.

6.



FASES DEL PENTEST

Explica cómo aplicarías cada fase al caso de Aurora Market.
¿Qué buscarías hacer en cada etapa?

1. **Reconocimiento**, pentesting basado en OWASP+PTES para aplicaciones web
Analizaría, la vulnerabilidad en base a OWASP, errores en configuración, redes, servidores, actualizaciones que hagan falta, inyección de código que se pudieran

infiltrar, accesos si hay algún tipo de issue con usuarios, accesos de más, y por ultimo los descuidos humanos que dejen vulnerable.

Y se necesitan clasificar como riesgo bajo, medio, graves y criticas, es importante agregar algún tipo de autorización sobre hasta donde podemos llegar, como un tipo de exploit conditions

2. **Análisis de vulnerabilidades**, si hay ambiente de prueba o producción, quizá iniciaría creando varios usuarios, o si nos darán usuarios que permisos tendremos, creo que herramientas como Nmap para la infraestructura que esta a nuestro alcance, si pudiéramos utilizar burp suite podríamos analizar toda la aplicación web, sin embargo también podríamos utilizar OWASP ZAP sin utilizar fuerza bruta la momento de hacer el test, verificando vulnerabilidades en cuanto URLs, parámetros, formularios, métodos de autenticación, SQL map también podría ayudar a analizar en caso de existir alguna inyección.
3. **Explotación**, verificaría con mis herramientas dependiendo la vulnerabilidad que busque, controlando que no sea demasiado y no impactar el sitio web o a sus usuarios, tomando en cuenta también nuestras condiciones de exploit.
4. **Post-Explotación**, si tenemos ya documentación de las varias vulnerabilidades que encontramos en el sitio, con aurora market se concreto que no se haría algo que fuera deliberado, podríamos solo tener nuestro top de vulnerabilidades bajas, medias, graves y criticas y hasta donde se llego para dar con ellas indicando que no se exploto la misma, pero si con detalles imágenes para tener en cuenta o hacer una remediación.
5. **Informe**, se documenta las vulnerabilidades encontradas en la tienda, todo se documenta en base a la metodología PTES+ OWASP, se brinda información detallada de cada una de las vulnerabilidades encontradas que se usó para encontrarlas, con capturas de pantalla (para mostrar más detalles y justificar) y la manera en como erradicar la vulnerabilidad, usando siempre un lenguaje no tan técnico para que cualquier persona de la organización pueda entender de que trata.

7. INVESTIGACIÓN

La metodología que elegí fue OWASP+PTES, debido a que en este proyecto es una aplicación web y la metodología OWASP nos puede ayudar a evaluar y remediar las vulnerabilidades con las que cuenta esta aplicación, además quise agregar el PTES ya que en esta metodología nos daría más estructura al pentesting, y llevar un orden de como evaluamos el sitio web (redes, aplicaciones web, sistemas operativos,

infraestructura,) siempre y cuando este dentro del marco acordado con nuestro cliente. Con las 2 metodologías obtendríamos estructura del pentest y con la owasp nos inclinaríamos a educar por primera vez a nuestros clientes ya que podríamos darles un acercamiento mas amigable a nuestra evaluación, con herramientas, recursos y documentación minuciosa sobre como tener menos riesgos y ser mas seguros para sus clientes y los trabajadores.